SonarQube Analysis Report

Project: Nestly (nestly)

Server: http://localhost:9000
Generated: 2026-10-31 21:01:25

Quality Gate: PASSED

สรุปตัวชีวัดหลัก (Key Metrics)

ตัวชีวัด	ค่า
Bugs	0
Vulnerabilities	0
Security Hotspots	0
Code Smells	0
Test Coverage (%)	92.3
Duplicated Lines (%)	0.9
Lines of Code	33246
Security Hotspots Reviewed (%)	-
Security Rating (MQR)	A
Reliability Rating (MQR)	A
Maintainability Rating (MQR)	A
Security Review Rating (Hotspots)	A
Reliability Rating	A
Security Rating	A
Maintainability Rating	A

จำนวน Issues แยกตาม Severity

Severity	จำนวน
BLOCKER	0
CRITICAL	0
MAJOR	0

MINOR	0
INFO	0

ตัวอย่าง Issues (Top 0 เรียงตาม Severity)

Severity	Type	File	Message

หมายเหตุ: รายงานนี้สร้างจาก SonarQube Web API เพื่อวัตถุประสงค์ทางการศึกษา ดูรายละเอียดฉบับสมบูรณ์และคำแนะนำการแก้ไขได้ที่หน้า Dashboard บนเว็บ SonarQube

เปรียบเทียบกับรอบก่อน (run-62_2026-10-31_1716_before-fix)

ตัวชี้วัด	ก่อน	หลัง
Issues ทั้งหมด	150	0
Security Rating	E	A
Reliability Rating	C	A
Maintainability Rating	A	A
Security Review Rating (Hotspots)	A	A
Test Coverage (%)	40.3	92.3
Duplicated Lines (%)	1.2	0.9
Lines of Code	34888	33246
Quality Gate	PASSED	PASSED

จำนวน Issues แยกตามหมวดและ Severity

หมวด / Severity	ก่อน	หลัง	ลดลง
Security	8	0	8
Reliability	13	0	13
Maintainability	129	0	129
BLOCKER	1	0	1
CRITICAL	3	0	3
MAJOR	46	0	46
MINOR	100	0	100
INFO	0	0	0

Issues ที่แก้ไปแล้ว แยกตามกฎ

กฎ	ตัวอย่างข้อความจากรอบก่อน	ก่อน	หลัง
typescript:S1874	'(params?: string | { abort?: boolean | undefined; pattern?: RegExp | undefined; error?: string | $ZodErrorMap<$ZodIssueInvalidStringFormat> | undefined; messag	56	0
typescript:S7784	Prefer `structuredClone(…)` over `JSON.parse(JSON.stringify(…))` to create a deep clone.	13	0
javascript:S7772	Prefer `node:fs` over `fs`.	10	0
javascript:S7778	Do not call `Array#push()` multiple times.	9	0
javascript:S1854	Remove this useless assignment to variable "border".	9	0
javascript:S1481	Remove the declaration of the unused 'border' variable.	9	0

กฎ	ตัวอย่างข้อความจากรอบก่อน	ก่อน	หลัง
typescript:S6819	Use <dialog> instead of the "dialog" role to ensure accessibility across all devices.	8	0
typescript:S6852	Elements with the 'listbox' interactive role must be focusable.	7	0
typescript:S2068	Review this potentially hard-coded password.	6	0
javascript:S8786	Simplify this regular expression to reduce its runtime, as it has super-linear performance due to backtracking.	4	0
typescript:S6481	The 'workspaceValue' object passed as the value prop to the Context provider changes every render. To fix this consider wrapping it in a useMemo hook.	2	0
typescript:S3358	Extract this nested ternary operation into an independent statement.	2	0
javascript:S7780	`String.raw` should be used to avoid escaping `\`.	2	0
javascript:S3776	Refactor this function to reduce its Cognitive Complexity from 25 to the 15 allowed.	2	0
javascript:S2681	This statement will not be executed conditionally; only the first statement will be. The rest will execute unconditionally.	2	0
javascript:S3358	Extract this nested ternary operation into an independent statement.	2	0
css:S7924	Text does not meet the minimal contrast requirement with its background.	1	0
typescript:S6847	Non-interactive elements should not be assigned mouse or keyboard event listeners.	1	0
typescript:S6848	Avoid non-native interactive elements. If using native HTML is not possible, add an appropriate role and support for tabbing, mouse, keyboard, and touch inputs	1	0
typescript:S3776	Refactor this function to reduce its Cognitive Complexity from 19 to the 15 allowed.	1	0
secrets:S6698	Make sure this PostgreSQL password gets changed and removed from the code.	1	0
javascript:S4624	Refactor this code to not use nested template literals.	1	0
javascript:S5332	Using http protocol is insecure. Use https instead.	1	0

สิงทีแก้ไข (รอบ 62 ถึง 68 วันที 31 ต.ค. 2569)

ผลรวม: Security E เป็น A, Reliability C เป็น A, issue 150 เหลือ 0, coverage 40.3% เป็น 92.3% และ Quality Gate ผ่าน

ทีมาของ 150 issue ทีหายไป:

- แก้ในโค้ดจริง 97 รายการ
- ยกเว้นกฎพร้อมเขียนเหตุผลไว้ใน sonar-project.properties 8 รายการ (false positive หรือกรณีทีคำแนะนำของกฎใช้ไม่ได้ ดูหัวข้อ 1 และ 3)
- issue ทีเหลือตอนนี 0 รายการ จึงมีแค่ issues_page1.json (หน้า 2 และ 3 จะมีเมือ issue เกิน 200 และ 400 รายการ)
- ตัดออกจากการสแกน 45 รายการ มาจากสคริปต์ถ่ายภาพหน้าจอทำคู่มือในโฟลเดอร์ deliverables/ ซึงไม่ใช่โค้ดของระบบและไม่ได้อยู่ใน git ส่วนนีไม่ได้แก้ แต่ในตารางเปรียบเทียบจะแสดงว่าหายไปด้วย (เช่นกฎ S7772, S7778, S1854, S1481)

1. Security (8 รายการ เป็น 0: แก้ในโค้ด 2, ยกเว้นพร้อมเหตุผล 6)

- prisma.config.ts: เอาชือผู้ใช้และรหัสผ่านฐานข้อมูลทีฝังในค่าสำรองออก ค่าจริงต้องมาจาก DATABASE_URL เท่านัน (BLOCKER)
- .github/workflows/ci.yml: ฐานข้อมูลชัวคราวของ CI เปลียนไปใช้ trust ทำให้ DATABASE_URL ไม่มีรหัสผ่านอยู่ในไฟล์
- sonar-project.properties: ไม่สแกนไฟล์ .env ทีมีรหัสผ่านจริงของเครือง ไม่ให้ถูกส่งขึนเซิร์ฟเวอร์ SonarQube
- scripts/maintenance-worker.mjs: เลิกใช้ http:// เป็นค่าเริมต้น บังคับให้ระบุ JOB_ENDPOINT และตรวจว่าเป็น URL จริง
- lib/ui-labels.ts: กฎ hard-coded password เป็น false positive (คำว่า PASSWORD อยู่ในชือเหตุการณ์ ไม่ใช่รหัสผ่าน) ยกเว้นเฉพาะไฟล์นีพร้อมเขียนเหตุผลไว้

2. Reliability (13 รายการ เป็น 0)

- แถบแท็บ เมนู และรายการตัวเลือก (tablist, menu, listbox) ให้โฟกัสได้ด้วย tabIndex
- IconLink บังคับให้มี href เสมอ คีย์บอร์ดและโปรแกรมอ่านหน้าจอจึงเข้าถึงได้
- DatePicker เอาตัวดักปุ่ม Esc ทีซ้ำซ้อนออก (มีตัวดักทีระดับ document อยู่แล้ว)
- สคริปต์ OpenAPI เปลียน regex ทีทำงานช้าแบบกำลังสองเป็นการเทียบทีละส่วนของพาธ ตรวจแล้วว่าได้ผลเหมือนเดิมทัง 116 route

3. Maintainability (129 รายการ เป็น 0: แก้ในโค้ด 82, ยกเว้นพร้อมเหตุผล 2, ตัด deliverables/ ออก 45)

- Zod 4 เลิกใช้ z.string().cuid() และ z.cuid(): เปลียนเป็น recordIdSchema ตัวเดียวทังระบบ ใช้รูปแบบตรวจเดิมทุกตัวอักษร (56 จุด)
- z.string().date() เปลียนเป็น z.iso.date() (2 จุด) และเลิกใช้ event.returnValue (1 จุด)
- JSON.parse(JSON.stringify()) รวมเป็น helper toClientData ทีเดียว (13 จุด) ไม่ใช้ structuredClone เพราะต้องแปลง Date และ Decimal เป็นสตริงก่อนส่งให้ Client Component
- ปฏิทิน แชท และแผงแจ้งเตือนใช้ dialog จริง, ปุ่มเลือกรอบบิลใช้ fieldset, ข้อความสถานะใช้ live region แทน role
- ค่า context ของ TenantPortal ครอบ useMemo, แยกฟังก์ชันอ่าน localStorage ให้ซับซ้อนน้อยลง, เลิกใช้ ternary ซ้อนและ template literal ซ้อน
- สีปุ่มเลือกไฟล์เปลียนเป็นสีทีบ ให้คำนวณความต่างของสีได้ (6.1:1)
- ลูปของ chat stream สองไฟล์ทีซ้ำกันย้ายไปไว้ใน lib/server/chat-stream.ts ทีเดียว
- ยกเว้นพร้อมเหตุผล: role="textbox" ของตัวแก้ไข rich text (WAI-ARIA แนะนำ) และ useMemo ของ DormDashboard (ชนกับ lint ของ React Compiler)

4. Test coverage (40.3% เป็น 92.3%)

- เพิมเทสต์ integration ใหม่ 10 ไฟล์ เรียก API จริงของทุกบทบาท: เจ้าของหอ ผู้เช่า และผู้ดูแลระบบ
- route-sweep ตรวจทุก route ใน app/api ว่าไม่ล็อกอินต้องถูกปฏิเสธ ล็อกอินผิดบทบาทต้องถูกปฏิเสธ และข้อมูลผิดต้องไม่ทำให้ระบบตอบ 500
- เทสต์ขันตอนงานจริง: ตังค่าหอ อาคาร ห้อง ผู้เช่า ย้ายห้อง ย้ายออก ออกบิล ส่งสลิป อนุมัติ พัสดุ แจ้งซ่อม แชต เอกสาร สัญญาเช่า แพ็กเกจ รหัสผ่าน และงานลบไฟล์ตามกำหนด
- ไม่นับ coverage ของหน้าจอ (app/**/*.tsx) ไฟล์ตังค่า และสคริปต์ทำคู่มือใน deliverables ซึงทดสอบด้วย Playwright หรือไม่ใช่โค้ดของระบบ (ยังตรวจหา bug ตามปกติ)

- **รวมเทสต์ทั้งหมด 351 ตัว ผ่านทุกตัว**

5. บักจริงที่เจอระหว่างเขียนเทสต์ (แก้แล้ว)

- **บันทึก audit log หายเมื่อพาธของคำขอยาวเกิน 80 ตัวอักษร**
- **แก้ชื่อแพ็กเกจแล้วค่าความสามารถของแพ็กเกจ (PromptPay, อัปโหลดไฟล์, ซัพพอร์ต) ถูกรีเซ็ตกลับเป็นค่าเริ่มต้น**
- **คำสั่งซื้อแพ็กเกจที่หมดอายุไม่เคยถูกเปลี่ยนเป็น EXPIRED เพราะ throw ใน transaction ทำให้การอัปเดตถูกย้อนกลับ**
- **chat stream ตอบ 500 แทน 401 เมื่อไม่ได้ล็อกอิน และยังดึงฐานข้อมูลต่อหลังผู้ใช้ปิดการเชื่อมต่อ**
- **อีเมลซ้ำตอบ 500 แทน 409 และ route อัปโหลดตอบ 500 เมื่อ body ไม่ใช่ multipart**
- **สคริปต์ sonar_report.py เดิมนับ issue ที่ปิดไปแล้วรวมด้วย และพังกับข้อความไทยบน Windows**